



ENGINEERING & INFORMATION SECURITY PRACTICES

Software Engineering & Technology Delivery

Document Reference: DL-SEC-001

Version: 1.0

Classification: Controlled Distribution

Owner: DISTILLOGIC TECHNOLOGIES

Actual practices. No unsupported certification claims.

This document describes the baseline engineering and information-security framework. Project-specific requirements remain subject to the applicable SOW, DPA or Security Schedule.

1. PURPOSE

This document describes the engineering, software-delivery and information-security practices applied by DISTILLOGIC TECHNOLOGIES to protect:

- client information;
- source code;
- credentials;
- development environments;
- software-delivery processes;
- infrastructure;
- project documentation;
- personal data;

other confidential information.

The specific controls applied to an engagement depend on:

- project scope;
- client architecture;
- security requirements;
- regulatory requirements;
- technical environment;

applicable contractual obligations.

Project-specific security requirements may be incorporated into the applicable Statement of Work, Data Processing Agreement or Security Schedule.

2. SECURITY PRINCIPLES

DISTILLOGIC applies the following core principles.

Least Privilege

Users receive only the level of access reasonably required to perform their responsibilities.

Need-to-Know

Access to Client Confidential Information is limited to authorised personnel with a legitimate project requirement.

Separation of Environments

Development, testing, staging and production environments should remain logically separated where applicable.

Controlled Change

Material changes to source code and production systems should follow defined review and release processes.

Security by Design

Security requirements are considered during architecture, development and deployment rather than only after implementation.

Traceability

Material technical changes, releases and access activities should be traceable where appropriate.

Defence in Depth

Multiple controls may be used to reduce dependence on a single security mechanism.

3. IDENTITY & ACCESS MANAGEMENT

Access to company and Client systems should be provided through individually identifiable user accounts.

Where appropriate, controls may include:

- centralised identity management;
- Single Sign-On;
- Multi-Factor Authentication;
- role-based access control;
- least-privilege permissions;
- privileged-access restrictions;
- periodic access review;

prompt access revocation.

Shared user accounts should be avoided where technically practicable.

Administrative privileges should be restricted to authorised personnel requiring them for legitimate operational purposes.

4. USER ONBOARDING & OFFBOARDING

Access should follow a controlled lifecycle.

Onboarding

Before project access is granted:

- role and access requirement are identified;
- appropriate authorisation is obtained;
- confidentiality requirements are confirmed;
- required accounts are created;

minimum necessary permissions are assigned.

Role Change

Where responsibilities change:

- permissions should be reviewed;
- unnecessary access should be removed;

new access should be approved where required.

Offboarding

Upon termination of employment, contract or project assignment:

- company access should be revoked;
- Client access should be removed;
- credentials should be disabled;
- project assets should be returned or transferred;

outstanding access rights should be reviewed.

5. SOURCE CODE SECURITY

Project source code should be maintained in controlled repositories.

Practices may include:

- private repositories;
- individual developer accounts;

- role-based repository permissions;
- branch protection;
- pull requests;
- peer code review;
- protected main or production branches;
- restricted repository administration;
- version history;

audit logging where available.

Production code should not normally be distributed through uncontrolled personal storage or consumer file-sharing services.

6. SOFTWARE DEVELOPMENT LIFECYCLE

DISTILLOGIC applies structured development practices appropriate to the engagement.

A typical lifecycle may include:

Requirements

- Architecture
- Development
- Code Review
- Testing
- Release Approval
- Deployment
- Monitoring

Security considerations may be incorporated throughout this lifecycle.

7. CODE REVIEW

Material production code changes should normally be reviewed before integration.

Review may consider:

- functional correctness;
- maintainability;
- coding standards;
- security implications;
- error handling;
- performance considerations;
- dependency usage;

testing coverage.

Where emergency production changes are required, an accelerated process may be applied with subsequent review and documentation.

8. BRANCHING & CHANGE CONTROL

Projects may use an agreed branching strategy according to Client and project requirements.

Typical controls may include:

- protected production branches;
- controlled merge permissions;

- pull-request approval;
- automated build validation;
- automated tests;

traceable change history.

Direct uncontrolled changes to production branches should be avoided.

9. DEVELOPMENT ENVIRONMENTS

Where appropriate, DISTILLOGIC uses separated environments such as:

Development

Engineering and implementation activities.

Test / QA

Functional, integration and automated validation.

Staging / UAT

Pre-production validation and Client acceptance.

Production

Live operational environment.

The exact environment model depends on Client infrastructure and project requirements.

Access to production should normally be more restrictive than access to non-production environments.

10. PRODUCTION ACCESS

Production access should be limited to personnel with a legitimate operational requirement.

Where practicable:

- development personnel should not receive unrestricted production access;
- privileged access should be controlled;
- production credentials should not be permanently embedded in application code;
- activities should be logged where technically supported;

access should be removed when no longer required.

Client security policies take precedence where stricter controls are required.

11. SECRETS & CREDENTIAL MANAGEMENT

Passwords, API keys, tokens, certificates and other secrets should not be stored directly in source code unless technically unavoidable and specifically controlled.

Preferred practices include:

- secret-management services;
- environment-specific secret storage;
- access restrictions;
- credential rotation;
- separate development and production credentials;

secure configuration mechanisms.

Examples may include approved cloud secret-management or key-vault services.

12. AUTHENTICATION & AUTHORISATION

Applications developed by DISTILLOGIC may implement appropriate authentication and authorisation mechanisms according to project requirements.

These may include:

- Single Sign-On;
- OAuth 2.0;
- OpenID Connect;
- token-based authentication;
- role-based access control;
- permission-based access;
- Multi-Factor Authentication;

session-management controls.

Authorisation decisions should be enforced server-side where applicable rather than relying solely on user-interface restrictions.

13. DATA PROTECTION

Client Data should be processed only for legitimate project purposes and according to contractual requirements.

Controls may include:

- access restrictions;
- encryption;
- environment separation;
- data minimisation;
- retention controls;
- secure deletion;
- pseudonymisation;

masking.

Where DISTILLOGIC processes Personal Data on behalf of a Client, the applicable Data Processing Agreement governs such Processing.

14. PRODUCTION DATA IN NON-PRODUCTION ENVIRONMENTS

Use of live Personal Data or commercially sensitive production data in development and testing should be minimised.

Where feasible:

- synthetic data;
- masked data;
- anonymised data;

pseudonymised data

should be used instead.

Where real production data is necessary, appropriate Client authorisation and safeguards should be applied.

15. ENCRYPTION

Where appropriate to the sensitivity of the data and technical environment, protection may include:

Data in Transit

Use of secure encrypted communication protocols such as TLS.

Data at Rest

Encryption of storage, databases, backups or other repositories where supported and appropriate.

Key Management

Encryption keys and secrets should be subject to controlled access.

Project-specific encryption requirements may be defined by the Client.

16. DEPENDENCY MANAGEMENT

Third-party software libraries and packages may introduce security risk.

Engineering practices may include:

- controlled package sources;
- dependency version management;
- vulnerability scanning;
- security update review;
- removal of unnecessary dependencies;

periodic dependency updates.

High-risk vulnerabilities should be assessed according to project impact and applicable remediation requirements.

17. SECURE DEVELOPMENT PRACTICES

Where relevant to the application, secure engineering may consider:

- input validation;
- output encoding;
- secure authentication;
- authorisation enforcement;
- API security;
- secrets protection;
- secure session handling;
- error-message control;
- logging;
- secure configuration;
- dependency management;

protection against common application vulnerabilities.

The exact security requirements depend on the application and Client risk profile.

18. SECURITY TESTING

Depending on project scope, security validation may include:

- source-code analysis;
- dependency scanning;
- API security testing;
- authentication testing;
- authorisation testing;
- configuration review;
- vulnerability assessment;

security-focused QA.

Formal penetration testing is included only where expressly agreed.

Where specialist penetration testing or independent security certification is required, DISTILLOGIC may work with an appropriately qualified specialist provider subject to Client approval.

19. CI/CD SECURITY

Continuous Integration and Continuous Delivery pipelines may be protected through:

- restricted pipeline administration;
- controlled build permissions;
- protected deployment stages;
- secret storage;
- environment-specific credentials;
- approval gates;
- automated quality checks;

audit trails.

Production deployment rights should be restricted according to project requirements.

20. INFRASTRUCTURE AS CODE

Where Infrastructure as Code is used, infrastructure definitions may be maintained under version control.

This provides:

- repeatability;
- traceability;
- controlled change;
- peer review;

environment consistency.

Infrastructure credentials should remain separate from source templates.

21. CLOUD SECURITY

Where cloud platforms are used, controls may include:

- identity-based access;
- role-based permissions;
- network restrictions;
- secure storage;
- secret-management services;
- monitoring;
- logging;
- backup;
- encryption;

resource isolation.

The exact implementation depends on the Client's cloud provider and architecture.

DISTILLOGIC can work within environments such as:

- Microsoft Azure;
- Amazon Web Services;
- Google Cloud Platform;

other approved infrastructure.

22. LOGGING & MONITORING

Applications and infrastructure may incorporate appropriate logging and monitoring.

Monitoring may cover:

- application errors;
- availability;
- infrastructure health;
- performance;
- security-relevant events;

deployment activity.

Logs should avoid unnecessary inclusion of sensitive Personal Data or credentials.

23. OBSERVABILITY

Where appropriate, production systems may use:

- logs;
- metrics;
- traces;
- dashboards;

alerts.

Observability enables engineering teams to diagnose:

- failures;
- performance issues;
- infrastructure problems;
- integration failures;

abnormal application behaviour.

24. BACKUPS

Where DISTILLOGIC is responsible for backup management, backup requirements should be defined according to:

- data criticality;
- Client requirements;
- Recovery Point Objective;
- Recovery Time Objective;
- retention period;

applicable infrastructure.

Backups should not be considered complete merely because multiple copies exist on the same affected system.

Where appropriate, backup data should be logically or physically separated from primary production systems.

25. RESTORATION & RECOVERY

Where applicable, restoration procedures should be documented and periodically validated.

Recovery arrangements may include:

- database restoration;
- infrastructure reconstruction;
- application redeployment;
- configuration recovery;

backup validation.

Formal disaster-recovery targets apply only where specifically agreed in the applicable SOW or Service Level Agreement.

26. BUSINESS CONTINUITY

DISTILLOGIC seeks to maintain reasonable continuity of engineering operations.

Continuity measures may include:

- cloud-based collaboration;
- controlled remote access;
- redundant communication channels;
- source-code repositories;
- backup procedures;

documented technical processes.

Client-specific Business Continuity or Disaster Recovery obligations shall be agreed contractually.

27. SECURITY INCIDENT MANAGEMENT

Suspected security events should be escalated appropriately.

A typical incident process may include:

Detection

- Assessment
- Containment
- Investigation
- Remediation
- Recovery
- Review

Material incidents affecting Client systems or information should be reported according to contractual and legal requirements.

28. SECURITY INCIDENT NOTIFICATION

Where DISTILLOGIC becomes aware of a confirmed security incident materially affecting Client data or systems under its control, DISTILLOGIC shall notify the Client:

without undue delay

subject to the applicable contractual and legal requirements.

Initial notification may be supplemented as additional information becomes available.

29. VULNERABILITY MANAGEMENT

Identified vulnerabilities should be evaluated based on factors including:

- severity;
- exploitability;
- affected system;
- data sensitivity;
- business impact;

production exposure.

Remediation priority should reflect actual project risk rather than vulnerability score alone.

Project-specific vulnerability remediation SLAs may be agreed separately.

30. PATCH MANAGEMENT

Where DISTILLOGIC manages the relevant infrastructure or application components, security updates and patches should be evaluated and applied according to:

- severity;
- compatibility;
- operational impact;

Client change-management requirements.

Emergency security fixes may require accelerated release procedures.

31. ENDPOINT SECURITY

Company-managed engineering endpoints should implement appropriate safeguards.

These may include:

- operating-system updates;
- device authentication;
- disk encryption;
- endpoint security tools;
- screen-lock controls;
- restricted administrator rights;

secure remote access.

Project-specific Client requirements may impose additional controls.

32. REMOTE WORK

Where remote work is permitted, project information should be accessed only through approved systems and devices appropriate to the engagement.

Controls may include:

- authenticated remote access;
- MFA;
- secure company devices;
- VPN where required;
- restricted local storage;

confidentiality safeguards.

Client-specific remote-access requirements shall be followed.

33. PERSONAL DEVICES

Use of personal devices for Client Confidential Information should be avoided unless:

- specifically authorised;
- appropriately secured;

consistent with Client requirements.

High-sensitivity projects may require exclusively managed company devices.

34. INFORMATION CLASSIFICATION

Information may be treated according to sensitivity.

A simple classification model may include:

Public

Information approved for public disclosure.

Internal

Information intended for internal company use.

Confidential

Business, project, client or technical information requiring restricted access.

Highly Restricted

Particularly sensitive credentials, security information, regulated information or other data requiring enhanced controls.

Client classification requirements may replace this model where applicable.

35. CONFIDENTIAL INFORMATION

Client Confidential Information shall be handled according to:

- the applicable NDA;
- MSA;
- SOW;
- Data Processing Agreement;

applicable law.

Access is limited to personnel with a legitimate need to know.

36. INFORMATION SHARING

Confidential project information should be shared only using appropriate authorised channels.

Uncontrolled sharing through:

- personal email;
- public repositories;
- public file-sharing links;

unauthorised messaging tools

should be avoided.

37. THIRD-PARTY SERVICES

Third-party services should be evaluated according to the sensitivity of the information they will process.

Where a third party will Process Client Personal Data, applicable DPA and Subprocessor requirements shall be followed.

Project teams should not introduce material third-party processing services without appropriate approval.

38. AI TOOLS & CLIENT INFORMATION

Client Confidential Information, source code, Personal Data or proprietary technical information should not be submitted to public or unapproved AI services where such submission would violate:

- Client instructions;
- confidentiality obligations;
- data-protection requirements;

intellectual-property requirements.

Use of AI-assisted engineering tools should comply with applicable Client and DISTILLOGIC policies.

Where required, Client-approved enterprise AI environments should be used.

39. PERSONNEL CONFIDENTIALITY

Personnel with access to Client Confidential Information should be subject to confidentiality obligations.

This may include:

- employees;
- contractors;
- consultants;

approved subcontractors.

40. SECURITY RESPONSIBILITIES

Security responsibilities should be clearly allocated between:

DISTILLOGIC

- for systems, code and processes under its control;

and

CLIENT

for Client-controlled infrastructure, users, credentials, systems and decisions.

Shared responsibilities should be documented where material.

41. CLIENT SECURITY REQUIREMENTS

DISTILLOGIC can operate under Client-defined security requirements where such requirements are:

- communicated;
- technically feasible;
- contractually agreed;

appropriately incorporated into project planning.

Examples may include:

- Client VPN;
- Client-managed devices;
- dedicated virtual desktops;
- restricted repositories;
- specific cloud regions;
- MFA requirements;
- security-training requirements;

background checks where lawful and appropriate.

Material requirements introduced after commercial agreement may require a Change Request.

42. SECURITY REVIEWS

DISTILLOGIC may participate in reasonable Client security assessments relevant to the engagement.

These may include:

- security questionnaires;
- supplier assessments;
- technical meetings;

- architecture reviews;
- data-protection reviews.

Information provided shall reflect actual DISTILLOGIC capabilities and controls.

43. AUDITS

Where contractually required, DISTILLOGIC may cooperate with reasonable Client audit requirements.

Audits should:

- relate to the applicable Services;
- respect confidentiality;
- avoid unnecessary disruption;
- protect information belonging to other clients;

be conducted under agreed procedures.

44. SECURITY CERTIFICATIONS

DISTILLOGIC shall only represent certifications that are currently and legitimately held.

Unless expressly confirmed in writing, this document does not represent that DISTILLOGIC is certified under:

- ISO/IEC 27001;
- SOC 2;
- PCI DSS;
- ISO 22301;

or any other specific certification framework.

Where a Client requires a particular certification, the requirement should be identified before contractual commitment.

45. SECURITY GOVERNANCE

Security responsibilities may be coordinated between:

- Company Management;
- Technical Leadership;
- Delivery Management;
- DevOps / Cloud Engineering;

Project Teams.

Project-specific Security Owners may be designated for higher-risk engagements.

46. EXCEPTIONS

Where a technical or operational exception to an established security practice is necessary, the exception should:

- be documented;
- identify the reason;
- identify the risk;
- identify mitigation measures;

receive appropriate approval.

Exceptions should not become permanent defaults without review.

47. CONTINUOUS IMPROVEMENT

Engineering and security practices should evolve according to:

- new technologies;
- identified risks;

- lessons learned;
- security incidents;
- Client requirements;
- regulatory developments;

industry practices.

Material lessons from project or security reviews should inform future improvements.

48. PROJECT-SPECIFIC SECURITY PLAN

For higher-risk or regulated projects, DISTILLOGIC and the Client may establish a separate:

Project Security Plan

which may specify:

- system architecture;
- data classification;
- access roles;
- cloud region;
- encryption;
- logging;
- vulnerability remediation;
- backup;
- disaster recovery;
- incident escalation;
- security contacts;

audit requirements.

49. SHARED RESPONSIBILITY PRINCIPLE

Security is a shared responsibility.

DISTILLOGIC is responsible for controls within its agreed scope.

The Client remains responsible for matters under its control, which may include:

- Client users;
- Client identity systems;
- Client infrastructure;
- Client configurations;
- Client-selected third-party systems;
- business-process controls;

lawful use of Personal Data.

Each SOW should identify material responsibilities where ambiguity could create security risk.

50. CONTACT

DISTILLOGIC TECHNOLOGIES

Software Engineering & Technology Delivery

Patras, Greece · European Union

Website

distillogic.gr

Security Contact

melas@distillogic.gr

Privacy Contact

melas@distillogic.gr

Commercial Contact

melas@distillogic.gr

DOCUMENT CONTROL

Document Reference: DL-SEC-001

Version: 1.0

Classification: Controlled Distribution

Complexity distilled. Technology delivered.

IMPORTANT

This document describes DISTILLOGIC's standard engineering and security framework.

Specific controls are implemented according to:

- the applicable project;
- technical architecture;
- Client requirements;
- contractual commitments;

infrastructure responsibilities.

Nothing in this document should be interpreted as claiming a certification, audit result, control implementation or regulatory status that has not actually been established and verified.